

Figure 2.5 An SQL injection attack occurs when user input is mixed into a SQL statement without the database being able to tell them apart. To the database, this SQL command with a funny owner name ends up looking like two separate statements followed by a comment.

When these elements are put together, the result is that the database sees two valid SQL statements: one that inserts a dummy row into the spaces table, and then another that destroys that table completely. Figure 2.6 is a famous cartoon from the XKCD web comic that illustrates the real-world problems that SQL injection can cause.

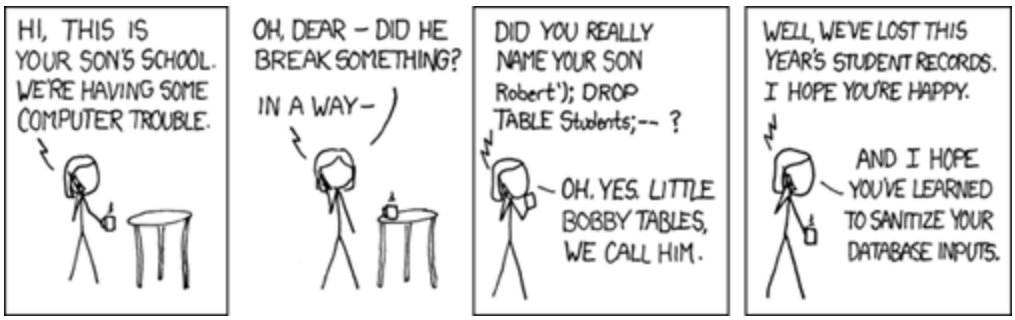


Figure 2.6 The consequences of failing to handle SQL injection attacks. Credit: XKCD “Exploits of a Mom” (https://www.xkcd.com/327/)